

PUBLIC PROFESSIONAL BRIEF

IAM and Vendor Access Brief

Identity architecture, MFA maturity, physical-to-logical access alignment, and third-party access governance for NorthGrid Energy.

Prepared by	Bernard Boakye Appiah
Scenario organization	NorthGrid Energy - fictional Ontario critical infrastructure operator
Document type	Identity and access management brief
Public disclosure	All content is sanitized and based on a fictional security assessment scenario.
Date	July 2026

Selected assessment metrics

Keycloak 24.0.4 IAM platform	RBAC + JIT Access model	Vendor privilege Priority risk
--	-----------------------------------	--

Public disclosure note: NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

Purpose and Executive Summary

This brief presents the identity and access management portion of the NorthGrid Energy assessment. It focuses on role design, MFA maturity, privileged access, physical-to-logical access alignment, and vendor access governance.

The assessment found that identity risk was not limited to passwords. Vendor access, shared administrator practices, physical access to OT-adjacent areas, and missing just-in-time controls created combined risk paths. The recommended direction is phishing-resistant MFA, named privileged accounts, PAM, vendor JIT access, and stronger physical controls around Tier 1 operational areas.

SCOPE

IAM Lab Environment and Scope

Component	Public-view description
Identity provider	Keycloak 24.0.4 deployed locally through Docker as a demonstration identity namespace.
Realm model	NorthGrid-specific realm used to model operational, administrative, help desk, and vendor access groups.
Authentication review	Username/password flow reviewed; OTP enrollment path identified; WebAuthn/FIDO2 recommended for phishing resistance.
Vendor access audit	Third-party relationships reviewed using least privilege, just-enough-access, and just-in-time access principles.
Physical-to-logical mapping	Facility zones mapped to logical sensitivity tiers to identify mismatches between physical access and system criticality.

IDENTITY DESIGN

Role-Based Access Model

The demonstration IAM model used scoped roles to show how users and vendors should receive access according to job purpose, not broad default privileges.

Role	Business purpose	Security value
ot-operator	Read-only operational monitoring and EMS-related visibility functions.	Supports separation between operational viewing and administrative change rights.
it-admin	Infrastructure management for IT systems.	Allows privileged IT access to be separated from standard user accounts.
helpdesk	Basic user support and account assistance.	Limits support staff to user-management workflows instead of domain-wide admin access.
vendor-hvac	Scoped access for building management support.	Prevents a building systems vendor from receiving broad network access.

The model supports RBAC at a basic level. To move toward policy-based access control, NorthGrid would need contextual rules based on device state, time window, location, user risk, approval ticket, and target system.

AUTHENTICATION

MFA and Authentication Assurance

TOTP-based MFA improves password-only authentication, but it is not fully phishing-resistant because a fake login page can still capture a one-time code. For high-risk NorthGrid access - VPN, administrators, vendors, and Microsoft 365 privileged roles - WebAuthn/FIDO2 or certificate-based authentication is the stronger target state.

Access path	Current concern	Recommended public-view target
VPN and remote access	MFA absent in starting posture.	Require phishing-resistant MFA for all remote access and vendor portals.
Privileged administration	Shared or standing privileges create accountability gaps.	Use named admin accounts, PAM checkout, approval, and session recording.
Vendor support	Persistent access remains active outside approved work windows.	Use JIT access with automatic expiry and ticketed approval.
Break-glass access	Emergency access may be needed during outages.	Maintain monitored break-glass accounts with strict logging and post-use review.

TIER MAPPING

Physical-to-Logical Access Alignment

A key IAM lesson was that logical access control can be weakened by physical access. If a general office badge allows someone near OT terminals, patch panels, or monitoring systems, the physical control does not match the logical sensitivity of the asset.

Zone	Logical sensitivity	Primary gap	Recommended control
Building lobby	Public / adjacent	Paper visitor logging and limited escort assurance.	Digital visitor management, ID verification, and escort policy.
Office floor	Tier 2	Shared floor access does not strongly separate general office from sensitive areas.	Separate NorthGrid access from general tenant/facilities access.
NOC	Tier 1	No separate badge control or internal CCTV in the starting posture.	Dedicated NOC access, CCTV, workstation screen protection, and escort enforcement.
Server room	Tier 0	Stronger controls exist, but access rights require periodic review.	Maintain badge control, add anti-passback, review access logs.
OT cabinet room	Tier 1	Same access level as general office despite OT-adjacent infrastructure.	Dedicated badge access, CCTV, anti-passback, OT-approved personnel only.

THIRD-PARTY ACCESS

Vendor Privilege Audit

The vendor audit identified cases where standing access was broader than the business need. In a critical infrastructure setting, third-party access must be treated as part of the attack surface.

Vendor relationship	Current risk pattern	Minimum necessary access	Priority
HVAC contractor	VPN access broader than BMS support need; no mature MFA/JIT controls.	VPN limited to BMS/HVAC subnet during approved support windows.	High
Managed SOC provider	Persistent privileged directory access beyond monitoring need.	Read-only monitoring by default; temporary elevated access through approved incident workflow.	High
GE Grid Solutions	Persistent EMS support access may create OT risk.	Time-limited access to EMS support system, approved by OT owner, with session recording.	High
Cloud backup vendor	Over-privileged Microsoft 365 access creates tampering and data exposure risk.	Backup-specific app permissions; no Global Administrator standing access.	Critical
Ended consultant access	Account remains active after engagement.	Disable access when contract ends; access recertification required.	Medium

CONTROL DESIGN

Recommended JIT Access Design

Access group	Trigger	Scope	Duration	Approval and recording
Managed SOC	Security incident ticket or investigation request.	Read-only by default; temporary elevation for specific response tasks.	1-4 hours.	NorthGrid security approval, MFA, session recording.
Cloud backup vendor	Approved backup, maintenance, restore, or emergency recovery request.	Backup-specific permissions only; no tenant-wide admin.	Approved window only.	IT/security approval with API activity logging.
GE Grid Solutions	EMS support ticket or OT maintenance window.	VPN/RDP only to approved EMS support path.	2-4 hours.	OT manager approval and session recording.
HVAC vendor	BMS maintenance ticket.	BMS subnet only; no broad network access.	Approved work period.	Facilities and security approval.

RECOMMENDATIONS

IAM Recommendations

- 1 Replace push-only or OTP-only MFA for high-risk access with phishing-resistant MFA such as FIDO2/WebAuthn.
- 2 Implement privileged access management for administrator and service accounts, including vaulting, rotation, approval, and session recording.
- 3 Remove shared domain administrator credentials and issue named admin accounts with least privilege.
- 4 Convert vendor access to just-in-time workflows with automatic expiry, MFA, ticket reference, and logging.
- 5 Align physical controls with logical sensitivity by securing NOC and OT cabinet areas separately from general office space.

SKILLS

Skills Demonstrated

Skill	Evidence in this brief
IAM architecture	Keycloak realm and role model for operational, administrative, support, and vendor users.
Zero trust thinking	Access scoped by identity, purpose, approval, time, and target system.
PAM/JIT/JEA	Vendor and privileged access redesign using just-in-time and just-enough-access concepts.
Physical-logical risk analysis	Mapping of facility zones to logical tiers and operational sensitivity.
GRC communication	Risk-prioritized recommendations written for a public professional audience.